Nhill Server 3.0 — Composant serveur

English: ../en/server.md

Le serveur Nhill (`nhill-server`) est le seul point d'accès aux données : Nhill Business, Nhill POS et Nhill Console lui parlent en HTTPS (API `v1`) ; aucune application ne se connecte à la base de données. Il est écrit en C++17, fonctionne sous Linux et s'appuie sur PostgreSQL 15 ou plus récent.

Sujet	Document
Mise en service retenue (VPS Hostinger en France)	deploiement-vps-hostinger.md
Installation manuelle, mise à jour, dépannage	guide-installation.md § 4 à 6
Toutes les clés de `/etc/nhill/server.env`	guide-configuration.md § 1
Base de données (rôles, migrations, sauvegardes)	base-de-donnees.md
Points d'accès de l'API (générés depuis le code)	reference-api.md
Sécurité et risques connus	securite.md, 03-audit-securite.md

1. Ce que fait le serveur

- Authentifie les utilisateurs (mots de passe Argon2id, jetons d'accès de 15 minutes, jetons de renouvellement à rotation) et les administrateurs de la console (mot de passe et code TOTP).
- Applique les droits : permissions du rôle, fonctions et limites de la formule de l'établissement, état de l'abonnement (accès complet, lecture seule, aucun accès). Les applications masquent ce qui n'est pas permis, mais c'est le serveur qui décide.
- Calcule et émet les documents (numérotation, taxes, arrondis, PDF A4 et ticket), tient le stock par mouvements, enregistre les paiements, les sessions de caisse et le journal d'activité.
- Fixe l'établissement de chaque transaction (`app.establishment_id`) : les tables de gestion n'exposent que les lignes de cet établissement (sécurité au niveau des lignes forcée).
- Exécute les tâches de fond (§ 4) et envoie les e-mails automatiques.

2. Installer

Cas	Procédure
Production sur un VPS Ubuntu 24.04 (Hostinger, France)	`deploy/vps/provision.sh` : PostgreSQL local, Caddy (TLS), pare-feu, sauvegardes chiffrées, surveillance ; recette automatique de 12 contrôles — deploiement-vps-hostinger.md
Autre serveur Linux, base PostgreSQL ou Supabase existante	paquet `nhill-server_3.0.0-1_amd64.deb` (Ubuntu 24.04 ou Debian 13), puis installation depuis Nhill Console ou en ligne de commande — guide-installation.md § 4
Poste de développement	`scripts/dev/dev-stack.sh start` (PostgreSQL jetable, jamais en production) — guide-developpement.md

Installé sans base, le serveur démarre en **mode installation** : il n'expose que `/health`, `/api/v1/meta` et `/api/v1/setup/*`, et affiche dans son journal un jeton d'installation valable 60 minutes (nouveau jeton à chaque redémarrage). Nhill Console utilise ce jeton pour créer les rôles, appliquer les migrations et enregistrer la configuration ; le serveur redémarre alors en fonctionnement normal.

3. Commandes

`nhill-server [--config FICHIER] COMMANDE` (le paquet utilise `/etc/nhill/server.env`).

Commande	Effet
`serve`	démarre l'API ; sans base configurée, démarre en mode installation ; refuse de démarrer s'il reste une migration à appliquer ou si la base a été migrée par une version plus récente
`setup --host … --port … --user … [--admin-email … --admin-name …]`	installation en ligne de commande (mot de passe de l'administrateur de la base lu sur l'entrée standard ou dans `NH_SETUP_DB_PASSWORD`, jamais conservé)
`migrate`	applique les migrations en attente avec le rôle propriétaire (`NH_MIGRATION_DATABASE_URL`)
`check`	vérifie la configuration, l'accès à la base, l'absence de migration en attente, et synchronise les profils pays
`run-jobs`	exécute une fois les tâches de fond (code de sortie 1 si une rotation de code échoue)
`admin-bootstrap EMAIL NOM`	crée le premier administrateur de la console, ou lui donne un nouveau jeton tant que son premier accès n'est pas terminé (jeton valable 30 minutes)
`version`	affiche la version du serveur et de l'API

Le fichier de configuration doit appartenir à `nhill` en mode 600 : le serveur refuse de démarrer s'il est lisible par d'autres comptes.

4. Tâches de fond

Toutes les `NH_JOBS_INTERVAL_SECONDS` secondes (300 par défaut ; `0` désactive) :

1. rotation des codes d'établissement arrivés à échéance ;
2. cycle des abonnements : passage à une formule inférieure déjà payée à la fin de la période, rappels avant l'échéance (calendrier de la formule, sinon de la plateforme), période de grâce quand l'échéance est passée sans paiement confirmé, puis formule de repli ou lecture seule à la fin de la grâce, expiration des demandes de paiement non payées ;
3. envoi des e-mails en attente (un fil dédié envoie aussitôt les codes de récupération) ;
4. nettoyages : tickets de rattachement et compteurs anti-abus expirés, demandes de réinitialisation terminées depuis 30 jours, e-mails envoyés ou abandonnés depuis 30 jours, sessions terminées depuis 90 jours.

La suppression définitive d'un établissement n'est jamais automatique : elle se fait depuis Nhill Console, 90 jours après la fin de l'accès (nhill-console.md § 4).

5. Exploitation

Besoin	Moyen
État	`curl -s https://api.<domaine>/health` → `{"database":true,"status":"ok"}` ; `503` si la base ne répond pas
Journal	`journalctl -u nhill-server` (une ligne JSON par événement)
Surveillance	sur le VPS : `nhill-healthcheck.timer` toutes les 5 minutes (services, PostgreSQL, API en local et en HTTPS, certificat, ports locaux, pare-feu, disque, dernière sauvegarde) avec alerte en cas d'échec

Besoin	Moyen
Sauvegardes	`nhill-backup.timer` chaque nuit à 02:30, fichiers chiffrés avec `age` — base-de-donnees.md § 5
Mise à jour, retour arrière	`nhill-update` : contrôle du paquet et de son empreinte, sauvegarde chiffrée, copie locale de la base, installation, attente de `/health`, retour arrière automatique en cas d'échec (`nhill-rollback`) — deploiement-vps-hostinger.md § 10
Réinstallation sur une machine neuve	deploiement-vps-hostinger.md § 11

6. Sécurité

- Le serveur écoute sur `127.0.0.1:8080` ; seul Caddy (TLS, HSTS) est exposé sur 80/443. `NH_TRUST_PROXY=1` uniquement derrière ce proxy.
- `NH_SECRET_KEY` chiffre les codes d'établissement, les secrets TOTP des administrateurs et les secrets des prestataires de paiement : gardez-en une copie hors du serveur, avec la clé privée des sauvegardes.
- Les rôles de base sont séparés : propriétaire (migrations), application (soumise à la sécurité au niveau des lignes, sans droit de définition), sauvegarde (lecture seule).
- Dépendances : bibliothèques des dépôts Ubuntu 24.04 / Debian 13 (cpp-httplib, libpqxx, libsodium, libharu, libcurl, zlib). Risques connus et décisions en attente : 03-audit-securite.md (R1 : cpp-httplib 0.14.3 des dépôts Ubuntu).

7. Codes d'erreur utiles

Code	Signification
`401 invalid_token`	jeton absent, expiré ou révoqué : l'application le renouvelle ou redemande la connexion
`401 invalid_credentials`	e-mail ou mot de passe incorrect (même réponse dans tous les cas)
`403 permission_denied`	le rôle n'a pas la permission
`403 feature_not_included`	la formule de l'établissement ne comprend pas la fonction
`402 subscription_suspended`	lecture seule (abonnement expiré ou suspendu) : consultation et export restent possibles
`409 plan_limit_reached`, `user_limit_reached`, `plan_register_limit`	limite de la formule atteinte

Les applications comparent leur version à `min_client_version` (`GET /api/v1/meta`) et demandent une mise à jour si elles sont trop anciennes. Liste complète et contrôles par route : reference-api.md.